

Compliance Agent (Agent 4)

Deep Technical Specification & Operational Manual

Executive Overview & Purpose

The Compliance Agent evaluates technical security findings against major global Governance, Risk, and Compliance (GRC) control frameworks, producing automated audit evidence checklists and quantitative compliance ratings.

1. Architectural Overview & Workflow

- Position in LangGraph Engine: Executes after DevSecOpsAgent in Pipeline A and Pipeline A_THEN_B.
- State Mapping: Maps all accumulated vulnerabilities in state.findings to formal compliance control IDs.
- State Propagation: Writes state.compliance_report and updates state.findings with framework control tags.

2. Supported GRC Framework Datasets (YAML)

- ISO 27001:2022: Maps to Controls A.5.15 (Access Control), A.8.8 (Management of Technical Vulnerabilities), and A.8.24 (Use of Cryptography).
- SOC 2 Type II: Maps to Trust Services Criteria CC6.1 (Logical Access), CC6.6 (Boundary Protection), and CC7.1 (Vulnerability Monitoring).
- NIST SP 800-53 Rev 5: Maps to Control Families AC (Access Control), SI (System & Information Integrity), and SC (System & Communications Protection).
- PCI DSS 4.0: Maps to Requirements 2 (Apply Secure Configurations), 3 (Protect Stored Account Data), 6 (Develop Secure Systems), and 8 (Identify & Authenticate).

3. Quantitative Compliance Scoring Algorithm

- Score Equation: $Score = \max(0, 100 - (Critical_Count * 25 + High_Count * 15 + Medium_Count * 5))$.
- Auditor Evidence Checklist: Generates structured Pass/Fail verification items with explicit justification for external audit submission.